

BÁO CÁO ĐIỀU TRA SỰ CỐ AN NINH MẠNG

INCIDENT RESPONSE REPORT

SSH Brute-Force Attack — Linux Victim Host

Khung tham chiếu: NIST SP 800-61 Rev.2 — Computer Security Incident Handling Guide

SOC / Blue Team Home Lab

Mã sự cố: INC-2026-0715-001

Người lập báo cáo: Nguyễn Minh Khoa

Ngày lập: 15/07/2026

Phân loại: Nội bộ — Lab cá nhân

1. Tóm tắt sự cố (Executive Summary)

Vào ngày 15/07/2026, hệ thống giám sát Splunk SIEM trong lab SOC/Blue Team đã phát hiện một chuỗi hoạt động tấn công dò mật khẩu (brute-force) nhắm vào dịch vụ SSH của máy chủ Linux victim (192.168.54.30). Nguồn tấn công được xác định là máy Kali Linux (192.168.54.40) đóng vai trò attacker trong mô hình lab, sử dụng công cụ Hydra với wordlist rockyou.txt để dò mật khẩu tài khoản "khoa".

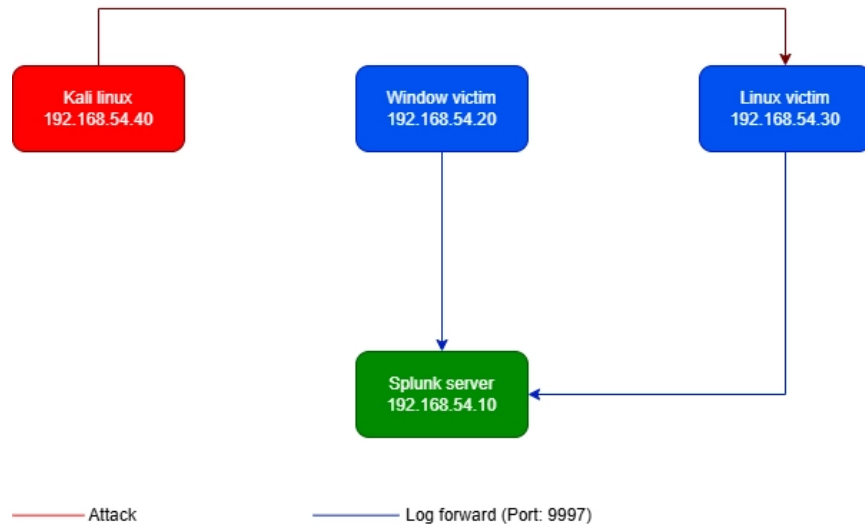
Cảnh báo tự động (SSH Brute Force Alert) đã kích hoạt thành công dựa trên luật phát hiện SPL được xây dựng sẵn, với hàng trăm lượt đăng nhập thất bại được ghi nhận trong các khung thời gian ngắn. Báo cáo này trình bày toàn bộ quá trình phát hiện, phân tích, và các bước xử lý/khắc phục theo khung NIST SP 800-61.

Mã sự cố	INC-2026-0715-001
Loại sự cố	Brute-force / Credential Access (MITRE ATT&CK T1110.001)
Mức độ nghiêm trọng	Trung bình (Medium)
Hệ thống bị ảnh hưởng	Linux victim — 192.168.54.30 (dịch vụ SSH, cổng 22)
Nguồn tấn công (IOC)	192.168.54.40 (Kali Linux)
Tài khoản mục tiêu	khoa
Công cụ phát hiện	Splunk Enterprise 10.4.1 — SPL detection + Real-time Alert
Trạng thái xử lý	Đã xác nhận qua log, đã có alert tự động; đã xác minh KHÔNG có đăng nhập thành công

2. Chuẩn bị (Preparation)

Trước khi xảy ra sự cố, hạ tầng giám sát đã được chuẩn bị với các thành phần sau:

- Splunk Enterprise được triển khai trên Ubuntu Server (192.168.54.10), đóng vai trò SIEM trung tâm.
- Splunk Universal Forwarder được cài trên Linux victim, forward log /var/log/auth.log về index "linuxlogs" (sourcetype: linux_secure) qua cổng 9997.
- Một luật phát hiện SPL (SPL detection rule) và Alert thời gian thực (Real-time Alert) đã được cấu hình sẵn để phát hiện các chuỗi đăng nhập SSH thất bại bất thường.
- Toàn bộ hệ thống được cô lập trong mạng Host-only VirtualBox (192.168.54.0/24), phục vụ mục đích thực hành, không ảnh hưởng hệ thống thật.



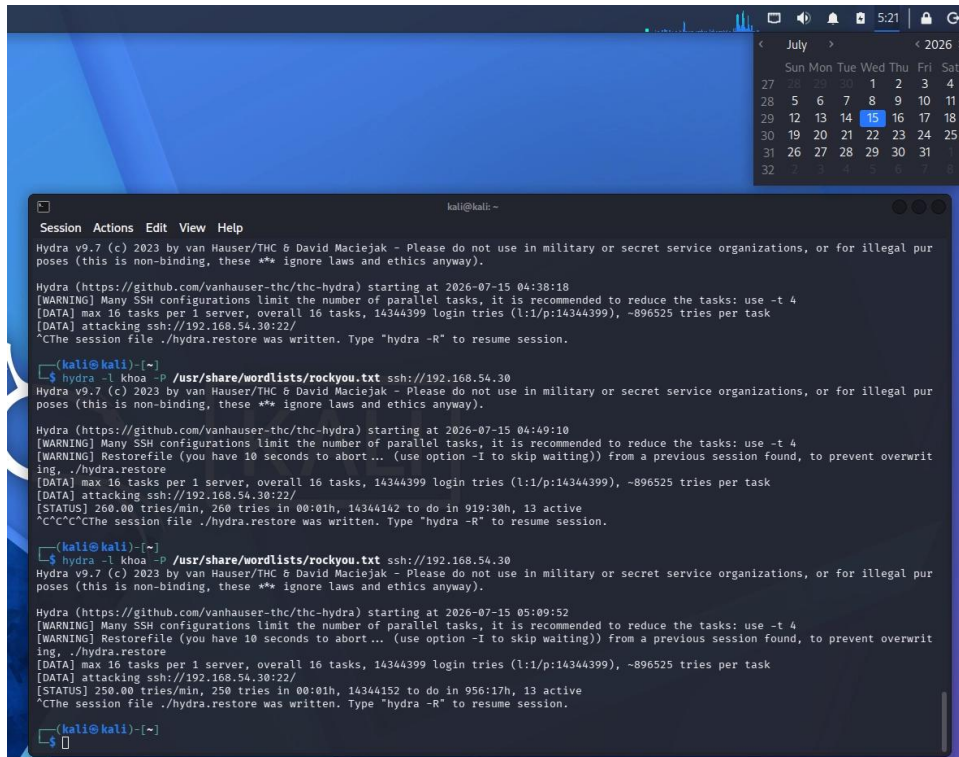
Hình 1 — Sơ đồ kiến trúc lab: luồng tấn công (đỏ) và luồng forward log (xanh) về Splunk server.

3. Phát hiện & Phân tích (Detection & Analysis)

3.1. Ghi nhận tấn công tại nguồn

Tại máy attacker (Kali Linux), công cụ Hydra v9.7 được sử dụng để thực hiện tấn công dò mật khẩu SSH nhắm vào 192.168.54.30, sử dụng wordlist rockyou.txt (14.344.399 khả năng mật khẩu) với 16 tiến trình song song, tốc độ trung bình 250–260 lượt thử/phút.

```
hydra -l khoa -P /usr/share/wordlists/rockyou.txt ssh://192.168.54.30
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak
[DATA] max 16 tasks per 1 server, 14344399 login tries
[DATA] attacking ssh://192.168.54.30:22/
[STATUS] 260.00 tries/min, 260 tries in 00:01h, 13 active
```

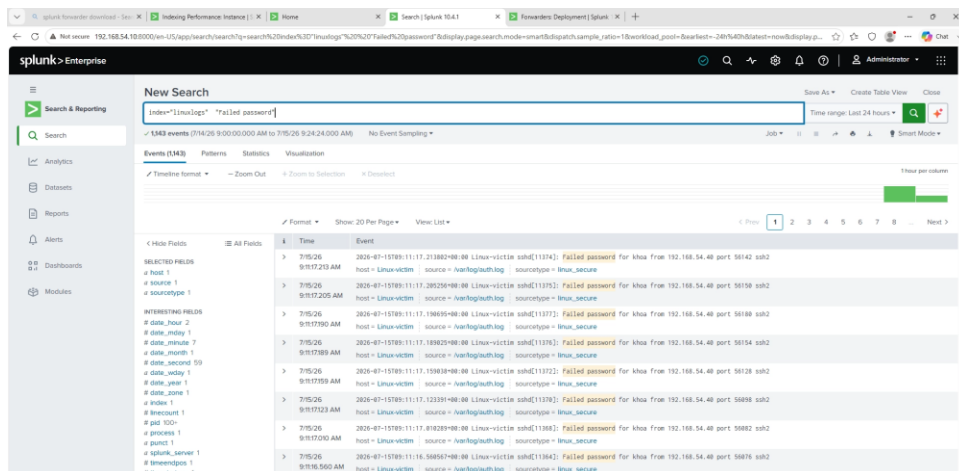


Hình 2 — Terminal Kali Linux thực hiện tấn công brute-force qua Hydra.

3.2. Phát hiện qua Splunk (log gốc)

Log gốc từ Linux victim (nguồn /var/log/auth.log, sourcetype linux_secure) ghi nhận liên tục các sự kiện "Failed password" từ nguồn 192.168.54.40, nhắm vào tài khoản "khoa" qua giao thức SSH2:

2026-07-15T09:11:17.213802+00:00 Linux-victim sshd[11374]: Failed password for khoa from 192.168.54.40 port 56142 ssh2

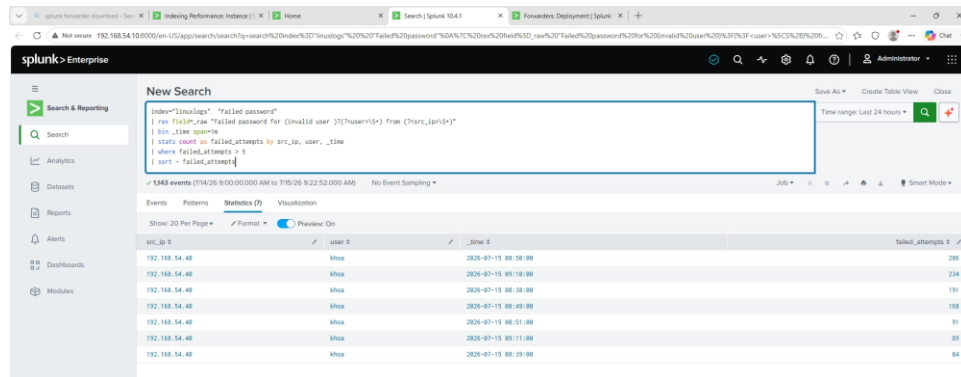


Hình 3 — Raw event trong Splunk, xác nhận nguồn (192.168.54.40), tài khoản mục tiêu (khoa) và dịch vụ bị tấn công (SSH).

3.3. Truy vấn phân tích (SPL detection)

Luật phát hiện SPL sau được sử dụng để tổng hợp số lượt đăng nhập thất bại theo từng IP nguồn, tài khoản, trong từng khung 1 phút, và lọc ra các trường hợp vượt ngưỡng 5 lần/phút — dấu hiệu đặc trưng của brute-force:

```
index="linuxlogs" "Failed password"
| rex field=_raw "Failed password for (invalid user )?(?<user>\S+) from (?<src_ip>\S+)"
| bin _time span=1m
| stats count as failed_attempts by src_ip, user, _time
| where failed_attempts > 5
| sort - failed_attempts
```



Hình 4 — Kết quả truy vấn SPL: các khung 1 phút có trên 80 lượt thất bại, đỉnh điểm 286 lượt/phút.

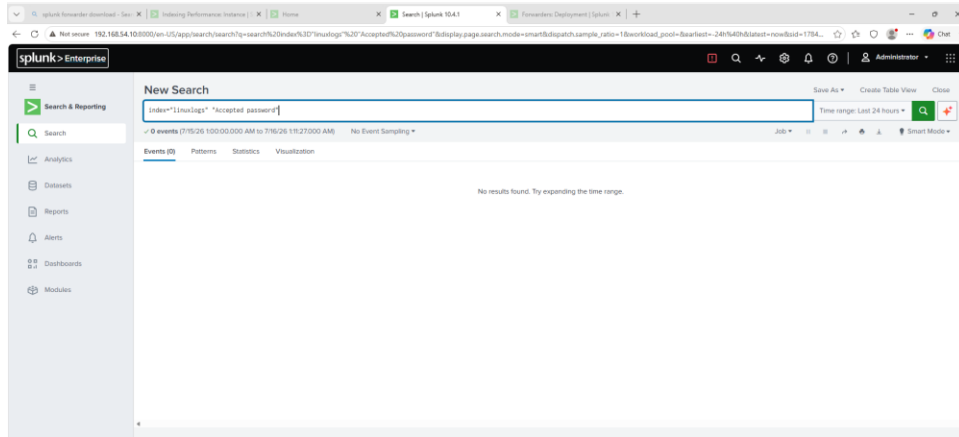
Kết quả cho thấy tổng cộng 1.143 sự kiện "Failed password" được ghi nhận trong khoảng 24 giờ (7/14 09:00 – 7/15 09:22), với các đỉnh điểm đáng chú ý:

Nguồn (src_ip)	Tài khoản	Thời điểm (bin 1 phút)	Số lượt thất bại
192.168.54.40	khoa	2026-07-15 08:50:00	286
192.168.54.40	khoa	2026-07-15 09:10:00	234
192.168.54.40	khoa	2026-07-15 08:38:00	191
192.168.54.40	khoa	2026-07-15 08:49:00	168
192.168.54.40	khoa	2026-07-15 08:51:00	91

Để xác minh khả năng dò trúng mật khẩu, một truy vấn bổ sung được thực hiện nhằm tìm sự kiện đăng nhập SSH thành công ("Accepted password") trong cùng index, trong 24 giờ gần nhất:

```
index="linuxlogs" "Accepted password"
```

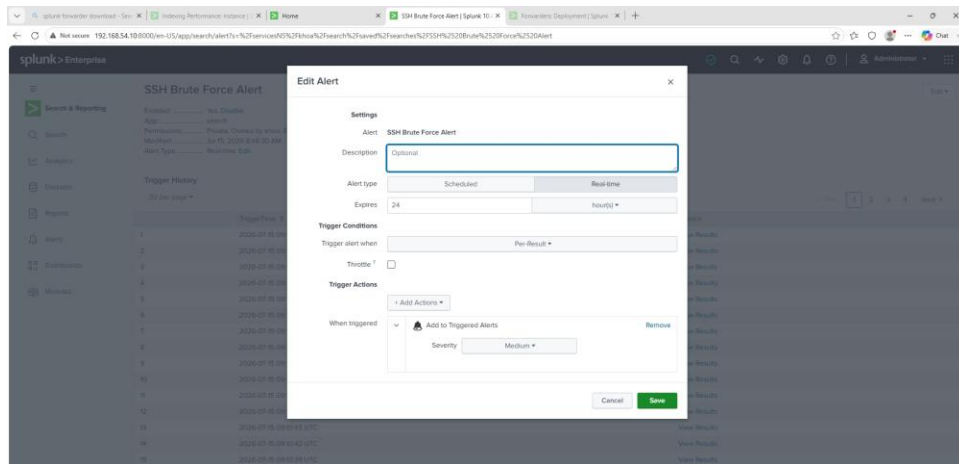
Kết quả trả về 0 sự kiện (0 events, khung 7/15/26 1:00 AM – 7/16/26 1:11 AM) — xác nhận không có bất kỳ lượt đăng nhập SSH thành công nào được ghi nhận trong toàn bộ khoảng thời gian diễn ra tấn công. Đây là bằng chứng trực tiếp loại trừ khả năng tài khoản "khoa" đã bị dò trúng mật khẩu trong đợt tấn công này.



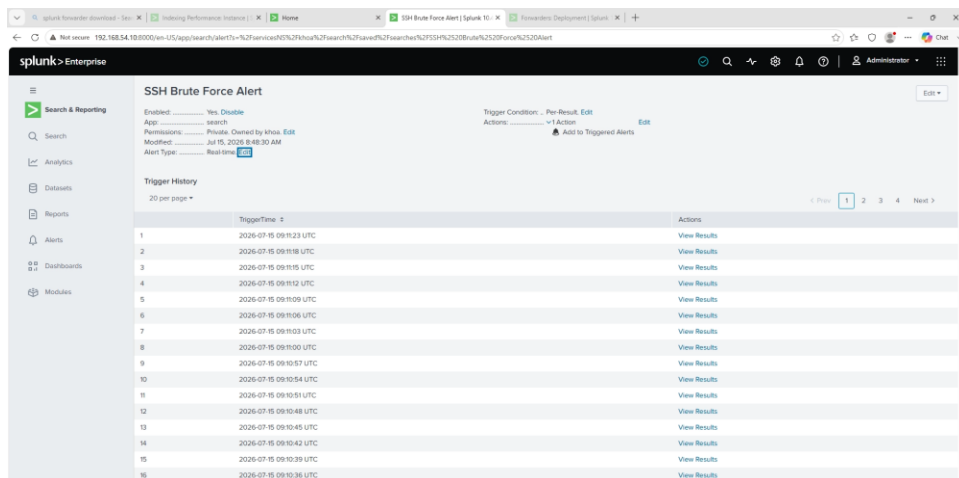
Hình 8 — Truy vấn xác minh: 0 events cho "Accepted password", xác nhận không có breach xảy ra.

3.4. Cảnh báo tự động (Alert)

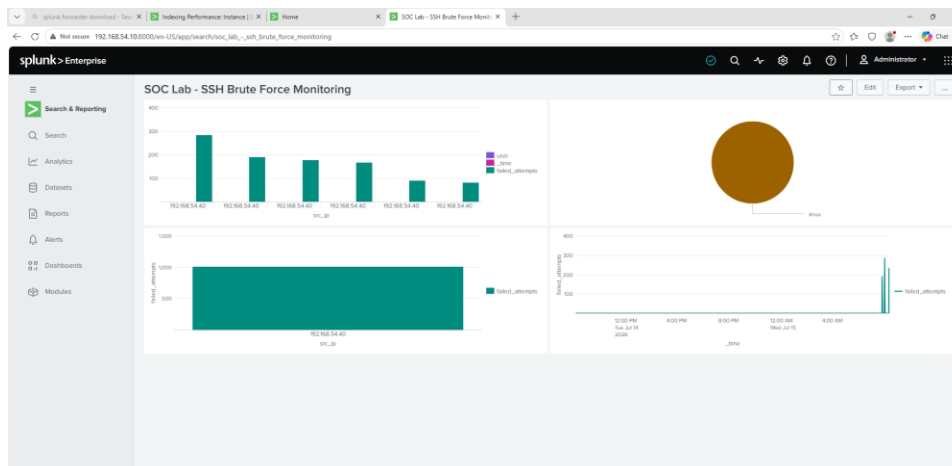
Một Alert thời gian thực ("SSH Brute Force Alert") dựa trên truy vấn SPL trên đã được kích hoạt tự động, ghi nhận hành động "Add to Triggered Alerts" với mức độ nghiêm trọng (Severity) = Medium.



Hình 5 — Cấu hình Alert: Real-time, Trigger khi = Per-Result, mức độ Medium.



Hình 6 — Trigger History: Alert kích hoạt liên tục trong khoảng 09:10:36 – 09:11:23 UTC, phản ánh cường độ tấn công cao.



Hình 7 — Dashboard giám sát tổng hợp: số lượt thất bại theo IP nguồn và theo thời gian.

4. Ngăn chặn (Containment)

Các bước ngăn chặn ngắn hạn được khuyến nghị áp dụng ngay để giảm thiểu rủi ro tiếp diễn:

- Chặn tạm thời địa chỉ IP nguồn 192.168.54.40 tại tường lửa của Linux victim: `sudo ufw deny from 192.168.54.40 to any port 22`.
- Giới hạn tốc độ kết nối SSH (rate-limiting) bằng iptables hoặc cài đặt fail2ban để tự động khóa IP sau một số lần đăng nhập thất bại.
- Tạm khóa hoặc theo dõi sát tài khoản "khoa" trong trường hợp nghi ngờ có khả năng bị dò trộm mật khẩu.
- Không tắt/khởi động lại dịch vụ SSH trong quá trình điều tra để tránh làm mất log phiên đang hoạt động (nếu có).

5. Khắc phục & Khôi phục (Eradication & Recovery)

5.1. Khắc phục (Eradication)

- Đã xác minh qua log (mục 3.3, Hình 8): không có sự kiện "Accepted password" từ nguồn tấn công — hệ thống chưa bị xâm nhập, không cần thực hiện các bước xử lý hậu-xâm nhập (persistence removal, thu hồi quyền truy cập...).
- Dù chưa bị xâm nhập, vẫn khuyến nghị đổi mật khẩu tài khoản "khoa" sang mật khẩu mạnh hơn như một biện pháp phòng ngừa, đồng thời chuyển sang xác thực bằng SSH key thay vì mật khẩu.

5.2. Khôi phục (Recovery)

- Gỡ bỏ rule chặn IP tạm thời sau khi xác nhận môi trường an toàn (áp dụng cho lab; trong môi trường thật cần đánh giá kỹ trước khi gỡ).
- Bật lại giám sát bình thường, xác nhận Alert và dashboard hoạt động ổn định sau khi xử lý.

- Cập nhật baseline lượt đăng nhập thất bại bình thường để tinh chỉnh ngưỡng phát hiện trong tương lai.

6. Bài học kinh nghiệm & Hành động tiếp theo (Lessons Learned)

- Chuyển xác thực SSH từ mật khẩu sang SSH key-based authentication, vô hiệu hóa PasswordAuthentication trong sshd_config để loại bỏ hoàn toàn nguy cơ brute-force mật khẩu.
- Triển khai fail2ban trên các máy victim để tự động chặn IP sau ngưỡng đăng nhập thất bại, giảm phụ thuộc vào phát hiện thủ công.
- Điều chỉnh cấu hình Alert từ chế độ "Trigger khi = Per-Result" sang ngưỡng theo số lượng kết quả (ví dụ > 5 sự kiện/phút) để giảm hiện tượng "alert fatigue" — hiện tại một đợt tấn công đã sinh ra hàng chục bản ghi Trigger History chỉ trong chưa đầy 1 phút.
- Bổ sung xác minh chủ động: chạy truy vấn tìm sự kiện "Accepted password" trùng khung thời gian tấn công để loại trừ khả năng breach, thay vì chỉ dựa vào suy luận không có bằng chứng ngược lại.
- Cân nhắc bổ sung MFA (xác thực đa yếu tố) cho các tài khoản quan trọng khi mở rộng lab sang các kịch bản nâng cao hơn.
- Xây dựng sẵn truy vấn xác minh "Accepted password" thành một bước chuẩn (standard operating procedure) mỗi khi phát hiện brute-force, để rút ngắn thời gian xác minh breach trong các sự cố thực tế sau này.
- Ghi nhận đây là kịch bản đầu tiên trong chuỗi bài tập SOC/Blue Team home lab; các phát hiện và quy trình ở đây sẽ làm nền tảng cho các kịch bản tấn công tiếp theo (Windows/Sysmon, lateral movement...).

7. Phụ lục — Danh mục minh chứng (Appendix)

Hình	Nội dung	Nguồn
Hình 1	Sơ đồ kiến trúc lab	Vẽ thủ công (draw.io)
Hình 2	Terminal Kali — lệnh Hydra thực thi tấn công	Kali Linux
Hình 3	Raw log gốc — sự kiện Failed password	Splunk — index=linuxlogs
Hình 4	Truy vấn SPL và bảng thống kê kết quả	Splunk Search & Reporting
Hình 5	Cấu hình Alert (SSH Brute Force Alert)	Splunk — Alerts
Hình 6	Lịch sử kích hoạt Alert (Trigger History)	Splunk — Alerts
Hình 7	Dashboard giám sát SSH Brute Force Monitoring	Splunk — Dashboards
Hình 8	Truy vấn xác minh "Accepted password" — 0 events	Splunk — index=linuxlogs